

Yelp disclosed on HackerOne: yelp.com and biz.yelp.com ATO via XSS...

Yelp disclosed on HackerOne: yelp.com and biz.yelp.com ATO via XSS... - Author not stated, HackerOne.

- Published: date not stated
- Original: <<https://hackerone.com/reports/2089042>>
- Preserved from: <https://hackerone.com/reports/2089042> (browser) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

119

[#2089042](#)

yelp.com and biz.yelp.com ATO via XSS + Cookie Bridge

Report

Timeline

[[image: lil_endian]](https://hackerone.com/lil_endian)

[lil_endian](#)

submitted a report to [Yelp](#).

July 28, 2023, 11:12pm UTC

Summary

I've found an XSS on `biz.yelp.com` where the unverified email will be reflected in a message, prompting the user to verify the email. This XSS can be combined with the cookie bridge functionality to target other uses with the XSS. The XSS can then be combined with the cookie bridge a second time to leak `HttpOnly` session cookies, and makes account takeover possible for both business accounts and regular accounts.

Description

XSS in business user email

When a business user has not verified their email, a message is shown telling them to verify the email. The user's email is reflected in this message, and it's possible to choose an email that will result in XSS. There is a 64 char limit on the chosen email, but it's just enough to achieve arbitrary javascript execution by choosing the email

Code•64 Bytes

```
1"<iframe/onload=eval(atob(location.hash.substring(1)))>"@calc.sh
```

and putting the payload base64 encoded in the url fragment

Image•74.06 KiB•F2544129: 2023-07-28-161149_1206x805_scrot.png

!

Image•236.19 KiB•F2544130: 2023-07-28-161210_1202x803_scrot.png

!

At this point this is just a Self-XSS, but I'll show how this can be used to target other users.

Yelp has local versions of the website, so a user requesting the site in danish, will be redirected to `yelp.dk` and a user requesting the site in german will be redirected to `yelp.de`. If a user is signed into `yelp.com` and wishes to change language to danish, they can't just be sent to `yelp.dk` without having to log in again since `yelp.com` and `yelp.dk` are 2 completely different domains in the eyes of the browser, and so the user's session cookies can't be used for both domains.

To solve this challenge, Yelp has implemented a Cookie Bridge that works by sending a GET request to `https://biz.yelp.com/cookie_bridge/store?dhl=da_DK`. The backend will take all the user's cookies and save them, redirect them to `https://biz.yelp.dk/cookie_bridge/retrieve?cookie_fsid=qCN_L-QbDTAVmqgKlAs2Dw&redir=%2F` which will then set the same cookies for the `yelp.dk` domain. The value of the `cookie_fsid` is unique for our cookies, and can only be used to retrieve the cookies once.

We can use the Cookie bridge to sign a victim into our account. While signed into our account on `biz.yelp.com` we send a request to `https://biz.yelp.com/cookie_bridge/store?dhl=da_DK`. This will result in a 303 redirect to `https://biz.yelp.dk/cookie_bridge/retrieve?cookie_fsid=qCN_L-QbDTAVmqgKlAs2Dw&redir=%2F`. Instead of following the redirect we can have a victim visit the link, and they'll then be signed into our business user on `biz.yelp.dk`. We can even use the `redir` parameter to redirect the victim to `/home#[OUR BASE64 ENCODED XSS PAYLOAD]` and have the XSS trigger

Using the XSS for ATO

The situation is as follows: The victim is logged in on `biz.yelp.com`. We sign the victim into the attacker account on `biz.yelp.dk` where our XSS triggers. The XSS can't make any changes to the victim account due to `biz.yelp.com` and `biz.yelp.dk` being different domains. For the XSS to be effective we need to sign the victim account into `biz.yelp.dk`. The attack looks like this:

- Victim is logged into `biz.yelp.com`.
- The victim clicks on our page, which opens a new tab. We'll call the opener tab "Tab A" and the new tab "Tab B". Tab B will load the cookie bridge retrieve endpoint that signs the victim into

our attacker account on `biz.yelp.dk` , and triggers the XSS:

Code•121 Bytes

```
1https://biz.yelp.dk/cookie_bridge/retrieve?cookie_fsid=qCN_L-  
QbDTAVmqgKIAs2Dw&redir=/home/%23[XSS PAYLOAD BASE64 ENCODED]
```

- Now we have javascript execution in Tab B. We now get a reference to Tab A and redirects it via `window.opener.location.href = "https://biz.yelp.com/cookie_bridge/store?dhl=da_DK"` . This will sign the victim into their own account on `biz.yelp.dk` . But our XSS is still alive in Tab B so we can now make requests from `biz.yelp.dk` with the victims session cookies.

At this point we're turned what started as a Self-XSS into regular XSS in the victims session. But we can improve the attack to steal the session cookies of the victims account, even though they're marked `HttpOnly` and not available from javascript. To do this we change the last step above and do the following instead:

- Using our XSS in Tab B we set several large cookies on `biz.yelp.dk` for the path `/cookie_bridge/retrieve` .:

Code•121 Bytes

```
1for (var i = 0; i < 15; i++) {document.cookie = X${i}=${'X'.repeat(1000)}; max-age=86400;  
path=/cookie_bridge/retrieve }
```

this will make all requests to `https://biz.yelp.dk/cookie_bridge/retrieve` fail, as openresty will complain that the cookie is too large. This will prevent the `cookie_fsid` token from being consumed:

Image•36.11 KiB•F2544131: 2023-07-28-170955_1204x418_scrot.png

!

- We now point Tab A to `https://biz.yelp.com/cookie_bridge/store?dhl=da_DK` which will attempt to transfer the victim account cookies to `biz.yelp.dk` , but will end up failing with a 400 error page since the cookie header is too large.
- Now Tab B can access Tab A's location via `window.opener.location.href` since they share the same origin `biz.yelp.dk` . Tab B can now leak the retrieve url for the victims session cookies, and the attacker can simply visit this url to be signed in as the victim. This works for both business accounts and regular yelp accounts.

POC and video

We create a business account with the email "

`<iframe/onload=eval(atob(location.hash.substr(1)))>"@calc.sh` without verifying it to get the Self-XSS gadget we need.

Using this account we make a request to `https://biz.yelp.com/cookie_bridge/store?`

```
dhl=da_DK&redir=/home/%23Zm9yICh2YXlgaSA9IDA7IGkgPCAxNjsGaSsrKSB7ZG9jdW1lbnQuY29va2lID0gYFgke2l9  
PSR7J1gnLnJlcGVhdCgxMDAwKX07IG1heC1hZ2U9ODY0MDA7IHBBhdGg9L2Nvb2tpZV9icmlkZ2UvcmlldmVgfQ  
p3aW5kb3cub3BlbmVynBvc3RNZXRzYXZlK8HtyZWRpcmVjdDoiaHR0cHM6Ly9iaXoueWVscC5jb20vY29va2lIX2JyaW  
RnZS9zdG9yZT9kaGw9ZGFfRESifSwglioKTsKc2V0VGltZW91dChmdW5jdGlvbGpIhthbGVydCgiYXR0YWNrZXIgaWY2Ful  
G5vdyBzaWduIGluGFZlZHpY3RpbSBieSBnb2luZyB0bzoilCsgd2luZG93Lm9wZW5lci5sb2NhdGlvbi5ocmVmKX0sIDU  
wMDApOw%3D%3D
```

 which returns a 303 redirect to `https://biz.yelp.dk/cookie_bridge/retrieve?`

Image•389.96 KiB•F2544134: 2023-07-28-172439_1624x1193_sctrot.png

Video•13.60 MiB•F2544137: biz.yelp-yelp-ato-poc.mp4

Impact

An attacker can leak the session cookies of a victim even though they're set as HttpOnly and sign in to the victims account. This works for both normal accounts and business accounts.

5 attachments

-

F2544129: [2023-07-28-161149_1206x805_scrot.png](#)

-

F2544130: [2023-07-28-161210_1202x803_scrot.png](#)

-

F2544131: [2023-07-28-170955_1204x418_scrot.png](#)

-

F2544134: [2023-07-28-172439_1624x1193_scrot.png](#)

-

F2544137: [biz.yelp-yelp-ato-poc.mp4](#)

!

Bot:

.

July 28, 2023, 11:12pm UTC

Hi there!

Thanks for submitting your report to us! Please expect a response within a week.

Best, The Yelp Security Team

[\[\[image: Calvin Li\]\]\(https://hackerone.com/calvinli\)](#)

[calvinli](#)

Yelp staff

changed the status to ****Triaged**.

July 29, 2023, 1:15am UTC

Hi [@lil_endian](#),

Thanks for the detailed report once again. We've deployed a patch for the XSS described in the beginning of your report, and we'll have more on the rest of it next week,

Thanks, Yelp Security

[\[\[image: Calvin Li\]\]\(https://hackerone.com/calvinli\)](#)

[calvinli](#)

Yelp staff

closed the report and changed the status to ****Resolved**.

August 10, 2023, 8:14pm UTC

Hi @lil_endian,

We've pushed additional patches that increase the security of the cookie bridge, and now consider this report resolved.

Best, Yelp Security

Yelp

rewarded lil_endian with a bounty.

August 10, 2023, 8:14pm UTC

calvinli

Yelp staff

requested to disclose this report.

August 10, 2023, 8:15pm UTC

!

lil_endian

.

August 11, 2023, 12:50am UTC

Thanks for the bounty!

\$3000 implies this report has been rewarded as a mid-range medium severity. After finding the initial XSS I put a lot of time and effort into coming up with a way to leak the victims HttpOnly session cookies to bump the impact and severity to High, so I'm a little disappointed if my efforts were wasted. I'm curious why you would only consider this a medium and not a high. Do you disagree with the CVSS score?

I intend to spend more time hacking on Yelp, so understanding how you rate bugs is really helpful.

!

lil_endian

.

August 17, 2023, 3:06pm UTC

@calvinli bumping just in case you missed my question above :)

!

lil_endian

.

August 23, 2023, 7:12am UTC

@calvinli bump again

!

[lil_endian](#)

.

August 28, 2023, 12:44pm UTC

I'd really appreciate an answer here...

[yelp-619654bd](#)

updated the severity from

high (8.8)

to medium.

August 28, 2023, 12:50pm UTC

[[image: Security Yelper]](<https://hackerone.com/yelp-619654bd>)

[yelp-619654bd](#)

.

August 28, 2023, 12:57pm UTC

Hello [@lil_endian](#),

Our internal assessment of this report gave a CVSS score of 6.4 and the bounty paid was based on that. We stand by our decision to award \$3000 and won't be increasing it at this time. That being said, we appreciate your quality report and look forward to read about anything else you may find.

Best, The Yelp Security Team

!

[lil_endian](#)

.

August 28, 2023, 1:17pm UTC

Can you please share the CVSS score metrics you used to rate this issue then?

You made 2 changes based on this report (fixed the XSS issue, and made changes to the cookie bridge) so I'm a little disappointed if you've rated this as a plain old XSS issue.

[[image: Security Yelper]](<https://hackerone.com/yelp-619654bd>)

[yelp-619654bd](#)

.

August 29, 2023, 7:28am UTC

Hello [@lil_endian](#),

This is the CVSS v3.1 Vector we used to calculate the score `AV:N/AC:H/PR:L/UI:R/S:U/C:H/I:H/A:N`.

I should also clarify that our bounty amounts does not depend only on the CVSS score, but on other factors too. In this case, we took into consideration the likelihood of this vulnerability being exploited, hence why we awarded \$3000.

Please keep banging away on the Yelps. We'd love to see what else you find.

Best, The Yelp Security Team

!

[lil_endian](#)

.

August 29, 2023, 8:12am UTC

Setting "Privileges Required" to "Low" makes no sense when an attacker can immediately bootstrap themselves from having no account to creating a free business account in less than a minute.

I don't really agree with the attack complexity being "High" either. There's no "conditions beyond the attacker's control" besides the user interaction which is captured by the "User Interaction" being set to "required". In my poc I manually created the cookie bridge link, because it's a proof of concept. A small script would be able to create the link, and the attack would be 100% deterministic, and require no manual work from the attacker.

I get that you're not going to change your mind, so I'll stop arguing.

But one final thing I want to mention. You said:

I should also clarify that our bounty amounts does not depend only on the CVSS score, but on other factors too. In this case, we took into consideration the likelihood of this vulnerability being exploited

I really think you should put this disclaimer in the program description. If the severity will be lowered because it's deemed unlikely that an attacker will put in the effort to find it / exploit it, people should know that before spending time looking for complex issues and chains.

Anyway, I'll get back to hacking on Yelp now.

[lil_endian](#)

agreed to disclose this report.

September 8, 2023, 7:22am UTC

This report has been disclosed.

September 8, 2023, 7:22am UTC